静的アーティファクトによるLLM支援マルウェア解析の帰属誘導と機能説明汚染

瀧花 昇大[1,a)]　武仲 正彦[1]

概要：LLM をリバースエンジニアリング環境と連携させ，マルウェアの機能や帰属を推定する手法が現れている．解析では，逆コンパイルコードに加え，ロケールやドライバ名などの静的情報も判断材料となる．しかし，これらは容易に偽装でき，LLM の推定を誘導し得る．本研究では，同一検体・同一プロンプトで，解析環境が LLM に返す静的情報のみを変え，Gemma 4 と Qwen3.5 を用いて LLM 支援マルウェア解析への影響を検証した．帰属側では，開発者名を付加した条件で，偽装の可能性を警告した Gemma の応答の 99.1%が，同じ情報を帰属根拠に採用し，対応地域を第 1 候補とした．また，ロケール付加による同方向の帰属誘導は Qwen3.5 でも確認された．機能側では，ドライバ情報を付加すると，Qwen3.5 でドライバ・カーネル関連機能を主要・補助機能として記載する応答が非付加条件の 0%から 82.7%に増加し，Gemma でも同様の傾向が確認された．さらに，最終的なマルウェア種別が維持された場合でも，付加情報に沿った機能が根拠由来や確認状態を区別されないまま説明へ取り込まれた．この機能説明汚染は，第二評価者による独立判定でも確認された．以上より，LLM は偽装の可能性を認識しても静的情報を根拠に採用し，帰属推定や機能説明を変化させ得ることを示した．これらの結果は，LLM 支援マルウェア解析では，コード上で確認された事実と静的情報からの推測を明確に区別して提示・評価する必要性を示唆する．

キーワード：マルウェア解析，LLM，帰属誘導，偽旗，機能説明汚染

Static-Artifact Steering in LLM-Assisted Malware Analysis: Evaluating Warning–Evidence Coexistence and Function-Explanation Contamination

Shota Takihana[1,a)]　Masahiko Takenaka[1]

Abstract: Large language models (LLMs) are increasingly being integrated with reverse-engineering environments to infer malware functionality and attribution. In addition to decompiled code, static information such as locale settings and driver names may also influence analysis. However, such information can be easily manipulated and may steer LLM-based inference. In this study, we investigated its impact on LLM-assisted malware analysis using Gemma 4 and Qwen3.5, while keeping the specimen and prompt fixed and varying only the static information returned to the LLM by the analysis environment. On the attribution side, under the developer-name addition condition, 99.1% of Gemma responses that warned of possible deception nevertheless used the same information as attribution evidence and ranked the corresponding region as the top candidate. Locale-based attribution steering in the same direction was also observed with Qwen3.5. On the functionality side, adding driver-related information increased the proportion of Qwen3.5 responses that described driver- or kernel-related functionality as a primary or auxiliary function from 0% to 82.7%, with a similar trend observed for Gemma. Furthermore, even when the final malware category remained unchanged, functionality consistent with the added information was incorporated into the explanation without clearly distinguishing its evidence provenance or verification status. This function-explanation contamination was also confirmed by an independent second evaluator. These results show that LLMs may use static information as evidence and alter attribution inferences or functionality descriptions even when they recognize that the information may be deceptive. They suggest that LLM-assisted malware analysis should explicitly distinguish code-verified facts from inferences based on static information and preserve the provenance and verification status of each claim.

Keywords: static artifacts, attribution steering, false flags, function-explanation contamination, LLM

© 2026 Information Processing Society of Japan

This paper is work in progress and not peer-reviewed.

1. はじめに

マルウェア解析では，通信，ファイル操作，永続化，認証情報窃取，暗号化，破壊処理などを調査し，検体の機能と攻撃目的を推定する．解析方法は動的解析と静的解析に大別され，静的解析では検体を実行せず，逆アセンブル，逆コンパイル，制御フロー，API 呼び出し，文字列，ヘッダ，リソースなどから処理を推定する．安全性と迅速性の観点から，静的解析は初期調査と詳細解析の重要な手段である．

静的解析で得られる情報には，実装そのものを確認する情報と，解析を補助する付随情報がある．逆コンパイル結果，制御フロー，API 呼び出し，データ処理は，検体が備える処理を確認する情報である．一方，ロケール，VersionInfo，CompanyName，ProductName，ファイル名，サービス名，デバイス名，埋め込み文字列などは，開発環境，想定用途，標的地域，既知ツールとの関連を推測する手掛かりとなる．本稿では，このような文字列・メタデータの付随的な痕跡を静的アーティファクトと呼ぶ．

近年では，Ghidra のようなリバースエンジニアリング環境と大規模言語モデル（Large Language Model: LLM）を Model Context Protocol（MCP）で連携させ，静的解析結果から機能説明，帰属仮説，解析レポートを生成する利用形態が現れている [1], [2], [3]．LLM は大量の逆コンパイル結果，API，文字列，メタデータを整理し，自然言語による解析結果へ統合できる一方，どの情報をどの程度の根拠として扱うかはモデルの判断に委ねられる．

ここで，静的アーティファクトの多くは実装そのものではなく，容易に追加・変更できる点が問題となる．特定地域を示すロケールや人名だけでは攻撃者を特定できず，ドライバ名やデバイス名が存在しても，実際に対応する処理が実装されているとは限らない．それにもかかわらず LLM がこれらを実装確認済みの情報と区別せずに扱うと，変更可能な情報が帰属候補や機能説明の根拠となるおそれがある．さらに，LLM がアーティファクトの偽装可能性を警告しても，その情報を判断根拠から排除しているとは限らず，最終的なマルウェア種別が変化しなくても，アーティファクトから推測された機能がコード上で確認された機能と区別されないまま説明へ取り込まれる可能性がある．**本稿では，後者の現象を「機能説明汚染」と呼ぶ．**したがって，LLM 支援解析の頑健性を評価するには，最終ラベルや警告の有無だけでなく，どの情報がどの主張の根拠として採用され，その由来や確認状態が保持されているかを評価する必要がある．

そこで本研究では，命令文を埋め込む prompt injection ではなく，通常の静的解析結果に見える非命令的なアーティファクトを対象とし，LLM 支援マルウェア解析における根拠利用への影響を調べる．同一検体について解析プロンプトとコード解析結果を維持し，LLM へ提示する静的情報だけを条件別に変更する．帰属側では，偽旗可能性の警告，付加情報の根拠採用，付加情報に対応する地域の Top-1 化を分離し，警告が根拠利用を抑制するかを評価する．機能側では，静的アーティファクトから示唆された機能の採用，実装未確認留保，最終マルウェア種別を分離し，最終種別が維持された場合にも機能説明が影響を受けるかを評価する．

本稿の貢献は次の 3 点である．第 1 に，実バイナリとコード解析結果を固定したまま LLM へ提示する静的情報だけを変更し，変更可能なアーティファクトが帰属推定と機能説明のどの段階へ影響するかを分離して評価する枠組みを示す．第 2 に，帰属側では，LLM が静的アーティファクトの偽装可能性を明示的に警告した場合でも，同じ情報を帰属根拠として採用し，最終順位へ反映し得ることを示す．第 3 に，機能側では，静的アーティファクトから示唆された機能がコード上で確認された機能と区別されないまま説明へ取り込まれ，最終的なマルウェア種別が維持された場合でも説明の頑健性が損なわれ得ることを示す．

2. 背景と関連研究

サイバー攻撃帰属は，技術的証拠に加えて標的，時系列，攻撃基盤，既知 IOC，作戦上の文脈を組み合わせる不確実な推論である [4], [5], [6]．Skopik らは，攻撃者が技術的アーティファクトを意図的に操作して帰属を誤誘導する false flag campaign を整理しており [5]，Olympic Destroyer の Rich header に関する偽装事例も，静的アーティファクトを単独で強い帰属証拠にできないことを示す [7]．また，NotPetya/ExPetr ではランサムウェア風の表層情報に対し，実装から Wiper と評価されており，表層情報と実装上の機能を区別する必要がある [8]．

LLM 支援リバースエンジニアリングでは，r2ai を用いたマルウェア解析において解析速度や説明品質の向上が報告される一方，誤りや誇張，省略に対する解析者の継続的な確認が必要とされる [3]．これに対し，LLM 支援 RE 自体を攻撃対象とする研究も現れている．Crawford らは，実行機能を変えない余分な文字列変数へ命令文を埋め込む prompt injection により，LLM を用いた逆アセンブル・逆コンパイル解析を誤誘導できることを示した [9]．SemAder はバイナリの構造と意味の双方を操作し，LLM ベースのバイナリ解析を回避する手法を扱う [10]．Santos-Grueiro は，バイナリ由来の観測情報が本来以上の命令権限や証拠能力を持つものとして扱われる Representation Confusion を定義し，同一由来の観測を独立した証拠として数える問題と provenance を考慮した防御を示している [11]．これ

[1] 長崎県立大学
University of Nagasaki
[a)] bs224040@sun.ac.jp

© 2026 Information Processing Society of Japan

に対し本研究は，実マルウェア解析出力において，帰属側の警告・根拠・順位と，機能側の根拠由来・確認状態・最終分類を分離して定量評価する点に特徴がある．

図 1 に本研究の位置付けを示す．既存研究は，偽旗による帰属誤誘導，LLM 支援マルウェア解析，命令文を用いる prompt injection，またはバイナリ由来情報の権限・証拠能力の混同を扱っている．本研究はこれらに対し，命令文を含まない通常の静的解析結果に見えるアーティファクトを実マルウェアの解析パイプラインへ付加し，帰属側では「偽装可能性警告・根拠採用・最終順位」を，機能側では「アーティファクト整合的機能の採用・根拠／確認状態の留保・最終種別」を分離して測定する．特に，警告が存在しても根拠利用が抑制されるとは限らないこと，および最終種別の維持が機能説明の頑健性を保証しないことを実測する点に特徴がある．

3. 実験設計と判定方法

3.1 評価対象と分析単位

本研究では実バイナリ自体を改変せず，GhidraMCP 互換 bridge が LLM へ返す静的解析結果にだけ条件別アーティファクトを付加した．これは，バイナリ改変に伴うコード差や静的解析結果差を交絡させず，LLM へ提示されるアーティファクトの影響を分離するための統制実験である．したがって，本実験は実バイナリへの偽旗埋込みそのものを評価するものではなく，解析パイプライン上で当該静的アーティファクトが観測された場合の出力変化を対象とする．検体ファイル，Ghidra プロジェクト，Ghidra 側の解析状態，解析プロンプトは変更しない．各試行は新規セッションとして実行し，同一検体・同一条件につき 20 試行を計画した．条件間で seed を対応させていないため，個別回答の前後比較ではなく，条件別割合，非付加条件との差，検体別結果を記述する．帰属側の分析単位は固定 6 検体，機能側は InfoStealer 3 検体に対する反復生成回答である．本稿の割合は検体集団に対する正答率ではなく，固定検体・固定条件下の回答分布を示す．

評価対象は，固定位置・固定回数でアーティファクトを直接与えた LLM 単体ではなく，ツール選択を含む LLM 支援解析パイプライン全体の条件差である．付加条件の全有効回答について，`list_strings` を介して対象アーティファクトが少なくとも 1 回 LLM へ返却されたことを実行ログから確認した．その後の再呼出しや提示回数・位置は LLM のツール選択に依存する．

3.2 共通環境と対象検体

実験環境は，Ghidra GUI，GhidraMCP プラグイン，アーティファクト付加 bridge，LLM で構成した．bridge は `list_strings` の返却時に，条件別アーティファクトを既存の文字列エントリと同じ返却形式で末尾へ追加し，条件を示すメタ情報は与えない．「ロケール付加」「Company 付加」等はメタデータ自体の改変ではなく，それらを示唆する文字列を `list_strings` へ追加した条件である．解析プロンプトでは外部検索，公開レポート，ハッシュ照合，正解ラベルの利用を禁止し，確認した関数，API，文字列，主要機能，補助機能，マルウェア種別，帰属候補を分けて記述させた．

帰属側の対象は Wiper 3 検体と InfoStealer 3 検体である．W1 は HermeticWiper，W2 は CaddyWiper，W3 は Destover として扱い，I1 は BeaverTail，I2 は LummaStealer，I3 は OskiStealer として扱った [12], [13], [14], [15], [16], [17]．機能側の対象は I1–I3 の InfoStealer 3 検体とした．公開情報上の説明は検体背景であり，実験中の採点用正解ではない．

I1–I3 の各ファミリについて，本研究で参照した公開分析はカーネルドライバの展開・ロード・通信を主要機能として報告していない [15], [16], [17]．ただし，これは個別バイナリにおける当該機能の不存在証明ではないため，本稿では機能の真偽ではなく，非付加条件との記述率差と付加情報の採用・留保を評価する．

本研究では，帰属誘導のケーススタディとして一つの地域を誘導先に設定した．以下では，付加情報が示唆するこの方向を「対応地域」と呼ぶ．本ケーススタディでは北朝鮮を対応地域とした．

本研究では Gemma 4 で複数条件を探索し，Qwen3.5 では帰属側のロケール付加条件と機能側のドライバ情報付加条件について，別モデルで同方向の現象が生じるかを限定的に確認した．Gemma では帰属側 5 条件と機能側 2 条件を探索した．その探索結果を踏まえ，Qwen3.5 では帰属側のロケール付加条件と機能側のドライバ情報付加条件を限定的な確認対象として選択した．非付加回答の重複を除き，Gemma 660 回答，Qwen3.5 275 回答の計 935 回答を人手確認した．図 2 に条件を示す．

Gemma では Gemma 4 26B-A4B IT の `UD-IQ4_NL` を llama.cpp release b9935 上で用い，temperature 0.3，Top K 40，Top P 0.9，Min P 0.03 とした [18], [19]．seed は固定せず，660 回答を分析した．

Qwen3.5-9B では `qwen3.5-9B-UD-Q4_K_XL.gguf` を用い [20]，その他の実験設定は Gemma と共通とした．

3.3 解析プロンプト

Wiper 用と InfoStealer 用のプロンプトは，冒頭の種別仮説だけが異なり，条件間では同じ検体種別用のプロンプトを用いた．共通部では，最初の静的情報収集として `list_strings` と `list_data_items` を必ず実行し，主要な判断に使う関数は `decompile_function` で処理内容を確認するよう要求した．また，「確認した事実と，そこからの推測は分けて説明」するよう指示し，帰属については「不

© 2026 Information Processing Society of Japan

研究	対象	誘導・問題設定	本研究との主な差分
Skopik ら [5]	サイバー攻撃帰属	技術的 artifact による false flag	LLM 支援 RE と出力内の根拠利用は未評価
Apvrille ら [3]	LLM 支援マルウェア解析	解析品質・速度・誤り	adversarial な artifact 条件は未評価
Crawford ら [9]	LLM 支援 RE	文字列中の命令による prompt injection	本研究は命令文を含まない静的 artifact を対象
SemAder[10]	LLM バイナリ解析	構造・意味の操作による解析回避	本研究は最終種別維持時も，機能説明の根拠由来と確認状態を分離評価
Santos-Grueiro[11]	LLM 支援 RE	観測情報の権限・証拠能力の混同	本研究は警告・根拠・順位と機能説明・最終分類を分離して定量評価
本研究	**LLM 支援マルウェア解析**	**非命令的な静的 artifact**	**警告・根拠・順位と，機能説明・留保・最終種別を分離**

図 1 関連研究と本研究の位置付け.

Fig. 1 Positioning of this study relative to prior work.

表 1 対象検体と SHA-256

Table 1 Analyzed specimens and SHA-256 values.

検体 ID	ファミリ	種別	SHA-256
W1	HermeticWiper	Wiper	`0385eeab00e946a302b24a91dea4187c1210597b8e17cd9e2230450f5ece21da`
W2	CaddyWiper	Wiper	`a294620543334a721a2ae8eaaf9680a0786f4b9a216d75b55cfd28f39e9430ea`
W3	Destover	Wiper	`e2ecec43da974db02f624ecadc94baf1d21fd1a5c4990c15863bb9929f781a0a`
I1	BeaverTail	InfoStealer	`0621d37818c35e2557fdd8a729e50ea662ba518df8ca61a44cc3add5c6deb3cd`
I2	LummaStealer	InfoStealer	`277d7f450268aeb4e7fe942f70a9df63aa429d703e9400370f0621a438e918bf`
I3	OskiStealer	InfoStealer	`9a4949ef95975afceb281a33708ea8bcd90be831112bb2d89e7e3ba64a3e119a`

明」で終えず実在する候補を 1–5 位で順位付けし，各候補に対応する国・地域名と確信度 0–100%を付すよう求めた．この forced-ranking は open-set 帰属性能を評価するためではなく，同一の順位付け条件下で付加情報が候補順位へ与える影響を観測可能にするための測定設計である．

代表的な Gemma 回答では，付加した `developer=RiChol-su` 等の開発者名を確認した文字列として挙げ，第 1 候補を「Lazarus Group (APT38)，北朝鮮，85%」とした一方，同じ文字列について「意図的な偽装（False Flag）である可能性」を弱い点として記載していた．

3.4 研究課題とコードブック

RQ1（帰属誘導）： 変更可能な帰属示唆情報を bridge の返却値へ付加した条件で，偽旗可能性警告，付加情報の根拠採用，および付加情報に対応する地域の Top-1 化は，回答内でどの程度併存するか．

RQ2（InfoStealer の機能説明汚染）： ドライバ情報付加によりドライバ／カーネル関連機能の記述率はどう変化し，その根拠由来・確認状態は最終出力上で明示されるか．また，最終種別維持時にも機能説明汚染は生じるか．

偽旗可能性警告と根拠利用の併存は，偽旗可能性警告 Yes と根拠採用 Yes が同一回答内で成立する場合を指す．そのうち付加情報対応地域 Top-1 も成立した回答を三者併存として集計する．この併存自体を帰属誤りとは定義しない．偽装可能な情報を補助的に利用すること自体は直ちに誤りではないため，本指標は「警告があれば当該情報の判断への影響が抑制される」とみなせるかを検証するための操作的指標として用いる．

最有力種別は，最終結論に InfoStealer，Credential Stealer，Wallet Stealer が明示された場合を InfoStealer 系，Wiper または破壊型が明示された場合を Wiper，それ以外の別種別が明示された場合をその他とした．最終結論に種別がない場合，または相互に矛盾する場合だけ不明とした．グループ名や機能語から最有力種別を補完しない．第一評価者がコードブックに基づいて 935 回答（Gemma 660 件，Qwen3.5 275 件）を人手確認し，確定判定のみを主集計に用いた．

3.5 機能説明汚染の操作的定義

本稿では，非付加条件とドライバ情報付加条件を比較し，主要・補助機能欄のドライバ／カーネル関連機能記述を共通指標とする．**アーティファクトの観測・言及自体は汚染としない．**付加情報に整合する内容を肯定的に採用した場合をドライバ情報採用 Yes，その近傍で文字列・メタデータ由来の推測，コード未確認，要検証を明示した場合を根拠由来・確認状態の明示 Yes とする．採用 Yes かつ根拠由来・確認状態の明示 No を機能説明汚染として扱う．

本定義は機能の不存在や解析過程での未確認を主張せず，最終出力上の根拠由来・確認状態のみを評価する．`kernel32.dll` 等の API 名，根拠欄だけの `DeviceIoControl`，不存在記述は計上しない．

3.6 評価者間一致度の確認方法

主判定の再現性を確認するため，帰属側と機能側につい

© 2026 Information Processing Society of Japan

固定要素： 検体，Ghidra プロジェクト，Ghidra 側の解析状態，検体種別ごとの解析プロンプト
⇓　GhidraMCP 互換 bridge が `list_strings` の返却直前に条件別情報を付加　⇓

条件	返却値への付加内容	主に示唆する内容	分析側
非付加	追加情報なし	比較基準	帰属・機能
Company 付加	`Taebaek Kernel Systems`; `Morning Calm Kernel Storage Driver`	企業・ドライバ	帰属
開発者名付加	`Ri Chol-su`; `Pak Kwang-hyok`; `Choe Yong-il`	人名・地域	帰属
政治メッセージ付加	`DPRK`; `Juche`; `Paektu` を含む文言	政治・地域	帰属
ロケール付加	`Locale=ko-KP`	`ko-KP`: 地域	帰属
ドライバ情報付加	`KPMNTDRV`; `kpmntdrv.sys`; `SERVICE_KERNEL_DRIVER`	ドライバ・カーネル	機能

図 2　偽旗を模した付加情報条件と解析パイプライン．検体，Ghidra 側の解析状態，解析プロンプト等の実験者側設定は条件間で維持した．

Fig. 2　Added-information conditions emulating false-flag artifacts and the analysis pipeline.

表 2　主指標のコードブック

Table 2　Codebook for the primary metrics.

指標	Yes	No
偽旗可能性警告	追加アーティファクトについて偽旗，意図的偽装，植え込み，帰属誤誘導可能性を明示	単に根拠が弱い，IOC 不足，不確実と記述
根拠採用	追加アーティファクトまたは意味カテゴリを，任意順位の候補または最終結論の肯定的な帰属根拠として使用	単なる観測・列挙，または明示的に根拠から除外
付加情報対応地域 Top-1	第 1 候補に付加情報が示唆する国・地域を明示	対応地域の明示なし，または別地域を明示
ドライバ／カーネル関連機能記述	ドライバの展開・ロード・操作，カーネル処理，デバイス通信，カーネルサービスを主要・補助機能欄へ肯定的に記述	API 名・根拠欄だけの登場，不存在記述，または種別説明・最終結論だけに登場
ドライバ情報採用	ドライバ情報付加条件で，付加したドライバ／カーネル／サービス／デバイス操作に沿う内容を主要・補助機能欄へ肯定的に採用	不採用，または種別説明・最終結論だけに登場
根拠由来・確認状態の明示	採用箇所の近傍で文字列・メタデータ由来の推測，コード未確認，要検証を明示	採用した機能について，文字列・メタデータ由来の推測，コード未確認，要検証のいずれも明示しない

て第二評価者による独立再判定を行った．帰属側では，付加情報に対する警告・根拠採用判定の再現性を確認するため，Gemma の 4 付加条件（Company 付加，開発者名付加，ロケール付加，政治メッセージ付加）× 6 検体の 24 層を対象とした．回答内容による恣意的な選択を避けるため，各層から試行番号順の先頭 5 回答を固定的に抽出し，計 120 回答とした．機能側では，有効 228 回答をモデル×条件×検体の 12 層に分け，各層 10 回答，計 120 回答を対象とした．

抽出後の判定では LLM 出力全文のみを参照し，条件ラベル，検体，試行番号および第一評価者の判定結果は参照させなかった．帰属側では表 2 の偽旗可能性警告，根拠採用，付加情報対応地域 Top-1 を独立に判定し，警告＋根拠採用および三者併存は各評価者の判定から派生的に算出した．機能側についても表 2 と同じ基準で独立再判定した．

3.7　統計分析

二値指標は分子，有効回答数，回答割合を主として記述し，反復生成における run-level proportion の参考値として Wilson 95%区間も併記した．条件間の変化はアーティファクト付加条件から非付加条件を引いた percentage point（pp）差でも記述する．回答は固定検体内にネストした反復であり，条件間で seed も対応していないため，回答を独立な検体標本とみなす仮説検定や paired 比較は行わない．Wilson 区間は run-level proportion の参考値に限って用い，独立なマルウェア標本に基づく推測区間や，マルウェア母集団・モデル一般への推測とは解釈しない．

Qwen3.5 の未取得回答は補完せず有効回答数を主分母とし，欠測を効果に最も不利に割り当てる感度分析も行った．

4.　帰属側の静的アーティファクト誘導

4.1　Gemma における偽旗可能性警告と根拠利用の併存

表 3 に主条件の検体別結果を，表 4 に偽旗可能性警告，根拠採用，付加情報対応地域 Top-1 の併存関係を示す．

非付加条件の付加情報対応地域 Top-1 は 5/120 件（4.2%，Wilson 95% CI: 1.8–9.4%）に対し，開発者名付加条件では 119/120 件（99.2%，CI: 95.4–99.9%）となり，95.0 pp 増加した．同条件では 115/120 回答（95.8%，CI: 90.6–98.2%）で三者が併存した．対応地域との関連が報告されている I1，W3 を除外しても Top-1 は 1/80 件対 79/80 件であり，傾向は維持された．

© 2026 Information Processing Society of Japan

表 3 帰属側主条件の検体別 Top-1．Gemma は開発者名付加，Qwen3.5 はロケール付加を示す．

Table 3 Per-specimen Top-1 results for the primary attribution conditions.

検体	Gemma 非付加 Top-1	Gemma 開発者名 Top-1	Gemma 三者併存	Qwen 非付加 Top-1	Qwen ロケール Top-1
I1	2/20	20/20	20/20	0/18	20/20
I2	1/20	19/20	19/20	1/20	14/17
I3	0/20	20/20	19/20	1/18	18/18
W1	0/20	20/20	19/20	0/20	19/20
W2	0/20	20/20	20/20	1/20	18/18
W3	2/20	20/20	18/20	1/17	17/17
合計	5/120	119/120	115/120	4/113	106/110

表 4 Gemma における警告と根拠利用および Top-1 の併存

Table 4 Coexistence of warnings, evidence use, and Top-1 outputs in Gemma.

条件	警告	根拠採用	Top-1	警告＋根拠	三者併存	三者併存／警告
Company	89/120	86/120	64/120	81/120	59/120	59/89
開発者名	116/120	120/120	119/120	116/120	115/120	115/116
ロケール	63/120	114/120	111/120	63/120	62/120	62/63
政治メッセージ	114/120	120/120	120/120	114/120	114/120	114/114

4.2 Qwen3.5 におけるロケール誘導の限定的確認

Qwen3.5 では，計画した各 120 試行のうち最終回答へ到達した非付加 113 回答とロケール付加 110 回答を分析した．付加情報対応地域 Top-1 は非付加条件 4/113 件（3.5%，Wilson 95% CI: 1.4–8.7%）に対し，ロケール付加条件 106/110 件（96.4%，CI: 91.0–98.6%）となり，差は 92.8 pp だった．同一のロケール付加では Gemma でも 111/120 件が対応地域 Top-1 となっており，別モデルでも同方向の変化が観測された．Qwen3.5 でロケールまたはその意味カテゴリを帰属根拠に用いた回答は 107/110 件（97.3%，CI: 92.3–99.1%）であり，偽旗可能性警告は 1 件も出なかった．したがって，対応地域 Top-1 かつ根拠採用となった 106 件では，ロケールが明示的な偽旗可能性警告を伴わず根拠と順位に反映された．

公開情報上，付加情報に対応する地域との関連が報告されている 2 検体（I1，W3）を除外しても，付加情報対応地域 Top-1 は非付加条件 3/78 件に対してロケール付加条件 69/73 件であり [14], [15]，主な傾向は維持された．また，欠測を効果に最も不利に割り当てても，非付加条件 11/120 件（9.2%）に対してロケール付加条件 106/120 件（88.3%）となり，79.2 pp の差が残った．

4.3 帰属側判定の評価者間一致度

帰属側 120 回答の独立再判定では，第一評価者との一致率は偽旗可能性警告で 118/120 件（98.3%，Cohen's $\kappa = 0.946$），根拠採用で 120/120 件（100%，$\kappa = 1.000$），付加情報対応地域 Top-1 で 120/120 件（100%，$\kappa = 1.000$）だった．不一致は偽旗可能性警告の 2 件に限られた．

派生指標でも，警告＋根拠採用は 118/120 件（98.3%，$\kappa = 0.951$），三者併存は 119/120 件（99.2%，$\kappa = 0.978$）で一致した．

5. 機能側の静的アーティファクト誘導

5.1 Gemma における機能説明汚染

Gemma の非付加条件では，InfoStealer 60 回答の主要・補助機能欄にドライバ／カーネル関連機能を肯定的に記述した回答は 0/60 件（0.0%，Wilson 95% CI: 0.0–6.0%）だった．ドライバ情報付加条件では 52/60 件（86.7%，CI: 75.8–93.1%）へ増加し，差は 86.7 pp だった．採用 52 件のうち 16 件は文字列・メタデータ由来の推測，コード未確認，要検証を明示した一方，36 件はそのような根拠由来・確認状態の明示を行わなかった．

59/60 件で InfoStealer 系が最有力種別として維持されており，機能説明汚染は最終種別の変更を必須とする現象ではなかった．

5.2 Qwen3.5 における未区別採用と最終種別維持

Qwen3.5 の非付加条件では，主要・補助機能欄のドライバ／カーネル関連機能記述は 0/56 件（0.0%，Wilson 95% CI: 0.0–6.4%）だったが，付加条件では 43/52 件（82.7%，CI: 70.3–90.6%）となり，82.7 pp 増加した．同一のドライバ情報付加では Gemma でも 0/60 件から 52/60 件へ増加しており，別モデルでも同方向の変化が観測された．第一評価者による主判定では，Qwen3.5 の該当 43 件はいずれも最終出力上で根拠由来・確認状態を明示せず，この傾向は 3 検体全てで観測された．

一方，最有力種別はドライバ情報付加条件 52/52 件で InfoStealer 系だった．したがって，最終種別だけを評価した場合には全回答が一貫して見える一方，機能説明では 43/52 件で付加アーティファクトに整合する機能記述が採用され，その根拠由来や確認状態が最終出力上で明示されなかった．欠測を効果に最も不利に割り当て，非付加条件

© 2026 Information Processing Society of Japan

の欠測 4 件を全て記述あり，付加条件の欠測 8 件を全て記述なしとしても，4/60 件（6.7%）対 43/60 件（71.7%）となり，65.0 pp の差が残った．

5.3 機能側判定の評価者間一致度

第二評価者による再判定では，非付加条件 60 件のドライバ／カーネル関連機能記述は 0/60 件だった．一方，ドライバ情報付加条件 60 件では，同機能の記述が 48/60 件（80.0%），付加したドライバ情報の採用が 47/60 件（78.3%）で確認された．採用 47 件のうち根拠由来・確認状態を明示したものは 13 件であり，第二評価者によるより保守的な判定でも，付加条件 60 回答中 34 回答（56.7%）で機能説明汚染が認められた．

第一評価者との比較では，ドライバ情報採用は 55/60 件で一致し，一致率 91.7%，Cohen's $\kappa = 0.715$ だった．根拠由来・確認状態の明示は，双方がドライバ情報採用 Yes とした 47 件中 42 件で一致し，一致率 89.4%，$\kappa = 0.698$ だった．各評価者の判定から派生した機能説明汚染は 50/60 件で一致し，一致率 83.3%，$\kappa = 0.645$ だった．同じ 60 件に対する機能説明汚染の判定は，第一評価者で 44 件（73.3%），第二評価者で 34 件（56.7%）であり，不一致 10 件はいずれも第一評価者 Yes・第二評価者 No であった．判定件数には差があるものの，付加条件で機能説明が影響を受けるという方向は共通した．

6. 考察

6.1 偽装可能性の警告と根拠利用の抑制は別問題である

本結果から，アーティファクトの偽装可能性を警告することと，その情報の証拠能力を低く評価して根拠利用を抑制することは，別の問題として扱う必要がある．Gemma の開発者名付加条件では，全 120 回答中 115 回答で偽旗可能性警告，付加情報の根拠採用，対応地域 Top-1 が併存した．偽装可能な情報を補助的に利用すること自体は直ちに誤りではないが，警告が出力されたという事実だけから，当該情報の判断への影響が抑制されたとはみなせない．

したがって，LLM 支援解析の頑健性を評価する際には，警告の有無だけでなく，その情報が根拠として採用されたか，さらに最終順位へどのように反映されたかを分離して確認する必要がある．本研究はモデル内部で偽装可能性をどのように表象したかを測定しておらず，観測できるのは出力上の警告，根拠利用，順位反映の関係である．

6.2 最終種別の維持は説明の頑健性を保証しない

最終的なマルウェア種別が維持されることと，その種別を支える機能説明が静的アーティファクトの影響を受けないことは，別の問題である．Qwen3.5 では，ドライバ情報付加条件の 52 回答すべてで最終種別が InfoStealer 系に維持された一方，主判定では 43 回答でドライバ／カーネル関連機能が主要・補助機能へ採用された．

解析プロンプトでは「確認した事実と，そこからの推測は分けて説明」と要求したが，Qwen3.5 の該当 43 回答では，最終出力上で根拠由来・確認状態を区別できる記述はなかった．

この 52/52 は分類自体の頑健性を示す結果とは解釈しない．粗い InfoStealer 種別仮説を事前に与えた設定で最終ラベルが変化しなかった場合でも，付加アーティファクトに整合する機能記述の根拠由来・確認状態が出力上で失われ得ることを示す．したがって，最終種別と説明の頑健性は分けて評価する必要がある．なお，機能説明汚染は機能不存在や解析過程での未確認を断定しない．

6.3 Evidence provenance を保持する出力設計

前二節から，LLM 支援解析では各主張の evidence provenance を保持する必要がある．帰属側では，偽旗可能性警告，付加情報の根拠採用，対応地域 Top-1 が同一回答内で併存し，機能側では根拠由来・確認状態が明示されない場合が観測された．共通する問題は，変更可能な静的情報が最終出力へ入る過程で provenance が失われ得る点にある．

本結果は，各帰属候補・機能について，根拠を少なくとも「逆コンパイル・制御フロー・API・xref で確認」「文字列・メタデータから推測」「未確認・要検証」に分けて保持する出力設計の必要性を示唆する．このように根拠由来を明示することで，解析者は警告や最終ラベルだけでは把握できない，変更可能な静的アーティファクトが判断のどこへ入り込んだかを監査できる．

7. 限界と今後の課題

本研究は帰属側 6 検体，機能側 3 検体，2 モデル，特定プロンプト・条件に限定される．また，公開分析の存在する既知検体を用いており，モデルの事前学習知識が解析出力へ影響した可能性を排除できない．付加文字列数・意味的顕著性も統制しておらず，アーティファクト種別間の誘導力は比較しない．中立的な同長文字列対照を設けず，付加位置も末尾に固定したため，文字列追加自体と提示位置の影響は分離していない．量子化オープンウェイトモデルのみを対象とし，他の LLM への一般化は未検証である．誘導先も単一の対応地域に限られ，関連が報告される 2 検体を除外しても主結果は維持されたが，他地域でも成立することや，地域固有の prior に依存しない効果であることは示していない．帰属は「不明」を許さない forced-ranking であり，open-set 判断には一般化せず，同一設定下の条件間順位変化のみを評価する．機能側は粗い種別仮説を事前に与えており，最終種別維持率に影響し得る．第二評価は帰属側・機能側ともに各 120 回答の抽出標本に限定しており，全 935 回答を二重判定したものではない．帰属側では各主指標の一致率 98.3–100%（$\kappa = 0.946$–1.000）と高い一

© 2026 Information Processing Society of Japan

致を示した一方，機能側では派生した機能説明汚染の一致率は 83.3%（$\kappa = 0.645$）であり，同一 60 回答の汚染判定は第一評価者 44 件，第二評価者 34 件と評価者差がみられた．また，第二評価者には判定時に条件ラベル等を参照させていないが，回答中のアーティファクトから条件を推測できた可能性は残る．

本実験は bridge 返却値へのアーティファクト付加による統制実験であり，実バイナリ改変を含む攻撃全体は評価していない．全付加条件で `list_strings` へ対象情報を追加した一方，seed，提示後のツール呼び出し系列，各機能主張と実行履歴の対応は統制していない．したがって解析過程内部の確認有無ではなく，最終出力上の根拠由来・確認状態を評価する．Qwen3.5 は一部未取得のため有効回答分析とした．今後は実行ログ保存と地域・モデル・検体の拡張が必要である．

8. まとめ

本稿は，同一検体・プロンプトで bridge 返却値へのアーティファクト付加だけを変え，帰属側では警告・根拠利用・順位を，機能側では機能説明・根拠由来／確認状態・最終種別を分離評価した．同一のロケール付加による対応地域 Top-1 化と，同一のドライバ情報付加による機能記述増加はいずれも Gemma と Qwen3.5 で同方向に観測された．また，偽旗可能性を警告しても同じ情報が根拠として採用され，対応地域 Top-1 と同一回答内で併存し得ること，および最終種別の維持が機能説明の頑健性を保証しないことを示した．

以上より, LLM 支援解析の頑健性は, 偽装可能性警告の有無や最終ラベルだけでは評価できない．各主張の evidence provenance を出力構造として保持し，実装確認済み事実，静的アーティファクト由来の推測，未確認・要検証の情報を分離して提示・評価する必要がある．

参考文献

[1] National Security Agency: Ghidra Software Reverse Engineering Framework. https://github.com/NationalSecurityAgency/ghidra

[2] Model Context Protocol: Introduction. https://modelcontextprotocol.io/docs/getting-started/intro

[3] Apvrille, A. and Nakov, D.: Malware analysis assisted by AI with R2AI, arXiv:2504.07574 (2025).

[4] Rid, T. and Buchanan, B.: Attributing Cyber Attacks, Journal of Strategic Studies, Vol.38, No.1–2, pp.4–37 (2015). doi:10.1080/01402390.2014.977382.

[5] Skopik, F. and Pahi, T.: Under false flag: using technical artifacts for cyber attack attribution, Cybersecurity, Vol.3, Article 8 (2020). doi:10.1186/s42400-020-00048-4.

[6] Baram, G. and Lin, H.: Navigating uncertainty in cyber conflict: incorporating false flags in the attribution process of offensive cyber operations, Information, Communication & Society (2025). doi:10.1080/1369118X.2025.2604662.

[7] Kaspersky GReAT: The devil's in the Rich header, Securelist (2018). https://securelist.com/the-devils-in-the-rich-header/84348/

[8] Ivanov, A. and Mamedov, O.: ExPetr/Petya/NotPetya is a Wiper, Not Ransomware, Securelist (2017). https://securelist.com/expetrpetyanotpetya-is-a-wiper-not-ransomware/78902/

[9] Crawford, B., Phillips, J. and McClure, P.: Automatically Attacking Software Reverse Engineering AI Agents, arXiv:2605.30667 (2026).

[10] Wang, Y., Kang, F., Shu, H., Xiong, X. B. and Yang, J.: SemAder: Evading LLM-Based Binary Code Analysis via Structure-Semantics Joint Induction, ACM Transactions on Privacy and Security, Vol.29, No.3, Article 33 (2026). doi:10.1145/3818619.

[11] Santos-Grueiro, I.: When Binaries Talk Back: Representation-Confusion Attacks on LLM-Assisted Reverse Engineering, arXiv:2607.12507 (2026).

[12] SentinelOne: HermeticWiper: New Destructive Malware Used in Cyber Attacks on Ukraine (2022). https://www.sentinelone.com/labs/hermetic-wiper-ukraine-under-attack/

[13] Cisco Talos: Threat Advisory: CaddyWiper (2022). https://blog.talosintelligence.com/threat-advisory-caddywiper/

[14] Baumgartner, K.: Sony/Destover: mystery North Korean actor's destructive and past network activity, Securelist (2014). https://securelist.com/destover/67985/

[15] Palo Alto Networks Unit 42: Contagious Interview: DPRK Threat Actors Lure Tech Industry Job Seekers to Install New Variants of BeaverTail and InvisibleFerret Malware (2024). https://unit42.paloaltonetworks.com/north-korean-threat-actors-lure-tech-job-seekers-as-fake-recruiters/

[16] Microsoft Threat Intelligence: Lumma Stealer: Breaking Down the Delivery Techniques and Capabilities of a Prolific Infostealer (2025). https://www.microsoft.com/en-us/security/blog/2025/05/21/lumma-stealer-breaking-down-the-delivery-techniques-and-capabilities-of-a-prolific-infostealer/

[17] Nadh, Y.: Swift Payment-Themed Malspam Delivers Oski Stealer, Infoblox Threat Intelligence (2021). https://www.infoblox.com/blog/threat-intelligence/cyber-campaign-briefs/swift-payment-themed-malspam-delivers-oski-stealer/

[18] Google: gemma-4-26B-A4B-it; Unsloth: gemma-4-26B-A4B-it-GGUF. https://huggingface.co/google/gemma-4-26B-A4B-it, https://huggingface.co/unsloth/gemma-4-26B-A4B-it-GGUF

[19] ggml-org: llama.cpp release b9935. https://github.com/ggml-org/llama.cpp/releases/tag/b9935

[20] Qwen: Qwen3.5-9B; Unsloth: Qwen3.5-9B-GGUF, UD-Q4_K_XL. https://huggingface.co/Qwen/Qwen3.5-9B, https://huggingface.co/unsloth/Qwen3.5-9B-GGUF

© 2026 Information Processing Society of Japan